



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

COMENTÁRIOS DO GESTOR

DUQUE DE CAXIAS - Prefeitura Municipal de Duque de Caxias

1. Introdução

Este documento orienta a manifestação da **DUQUE DE CAXIAS** na fase de comentários do gestor. Conforme o caso, a manifestação poderá tratar dos achados e situações de inadequação registrados no Relatório Individual Preliminar, dos itens avaliados como não conformes na etapa de avaliação das evidências ou da ausência de resposta válida ao questionário iGovTI 2026.

A manifestação deve ser apresentada no questionário eletrônico de comentários do gestor, observando-se apenas as seções disponibilizadas para a organização.

Quando houver achados, a organização deverá informar se concorda ou discorda de cada situação apontada e, quando couber, apresentar comentários, justificativas e documentação comprobatória. Nas questões-base indicadas na seção de reavaliação de evidências, a organização poderá apresentar esclarecimentos, retificações ou evidência suplementar para reanálise dos itens avaliados como não conformes. Quando não houver resposta válida ao questionário iGovTI 2026, a manifestação deverá se limitar a esclarecimentos, comprovação de eventual envio anterior ou justificativa para a ausência de resposta.

A etapa de comentários do gestor é desejável, mas tem caráter opcional para a organização auditada. Sua finalidade é permitir que o gestor apresente esclarecimentos sobre fatos, retifique informações, informe providências adotadas ou planejadas e encaminhe documentação complementar pertinente.

Considerando a natureza da solicitação, relativa aos comentários dos gestores sobre achados de auditoria, o prazo para finalização e envio do questionário é **improrrogável**, conforme o item 8.4 do Manual de Auditoria do TCE-RJ, e se encerra em **10/07/2026**.

Recomenda-se que o questionário seja preenchido com antecedência. Eventuais solicitações de esclarecimento poderão ser encaminhadas para o e-mail **auditoriati@tcerj.tc.br**.

Achado 1 – Estrutura de TIC insuficiente para coordenar, gerir e sustentar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “Área de TIC sem atribuições formais suficientes para planejamento, coordenação, gestão, execução, monitoramento e controle da TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Modelo básico de governança e gestão de TIC inexistente ou insuficiente quanto a papéis, responsabilidades, objetivos, indicadores, metas ou acompanhamento.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Comitê de TIC ou instância equivalente não instituído formalmente.”
apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Inexistência ou fragilidade do processo formal de planejamento de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência de aprovação formal do plano de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Plano de TIC sem alinhamento adequado ao planejamento institucional.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Plano de TIC sem vínculo demonstrado com orçamento e contratações de TIC**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência de acompanhamento, revisão ou atualização periódica do plano de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “Ausência de força de trabalho dedicada à TIC ou à segurança da informação.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“A organização não definiu o quantitativo necessário de pessoal de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Ausência de cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Perfis profissionais de TIC e segurança da informação inexistentes, insuficientes ou não utilizados na escolha de gestores.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Lacunas de competências dos colaboradores e gestores de TIC e segurança da informação não são identificadas ou tratadas.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação “**Inexistência ou insuficiência do catálogo de serviços de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Ausência ou fragilidade na definição e no monitoramento de níveis mínimos de serviço de TIC.” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Inexistência ou fragilidade do inventário de ativos de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Ausência ou fragilidade do processo de gestão de configuração.**” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação **“Inexistência ou fragilidade do processo de gestão de incidentes de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

O Relatório Individual Preliminar apresenta as situações que fundamentaram este achado, as evidências consideradas, os critérios aplicados e as propostas de encaminhamento formuladas pela Equipe de Auditoria.

A **DUQUE DE CAXIAS** poderá apresentar comentários sobre as situações abaixo, inclusive quanto às providências adotadas ou planejadas, às propostas de encaminhamento e às consequências práticas de sua implementação.



No que tange à situação **“Inexistência ou fragilidade de processo formal e padronizado para contratações de TIC.”** apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “**Contratações de TIC sem análise prévia e aprovação técnica obrigatória da área de TIC.**” apontada no Relatório Individual, a organização:

- ☐ Concorda e já atendeu às propostas de encaminhamento
- ☐ Concorda e já está atendendo às propostas de encaminhamento
- ☐ Concorda, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



No que tange à situação “Contratações de TIC sem alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária.” apontada no Relatório Individual, a organização:

- ☐ Concorde e já atendeu às propostas de encaminhamento
- ☐ Concorde e já está atendendo às propostas de encaminhamento
- ☐ Concorde, mas ainda não adotou nenhuma medida para atender às propostas de encaminhamento
- ☐ Discorda da sinalização de inadequação

Caso concorde, total ou parcialmente, com a situação apontada será apresentada a caixa de texto a seguir para que o gestor possa registrar comentários, caso julgue como necessário.

Caso desejável, encaminhem seus comentários contemplando a perspectiva da organização e as ações corretivas que pretendem tomar, bem como avaliação sobre as propostas de determinação e/ou recomendação formuladas, informando sobre as consequências práticas de sua implementação e eventuais alternativas:

Caso discorde da situação apontada será apresentada a caixa de texto a seguir para que o gestor possa apresentar as razões da sua discordância e o envio de documentos.

Ajude-nos a entender por que você escolheu a opção acima:

Caso necessário, envie documentos que evidenciem suas justificativas

Apenas um arquivo PDF ou ZIP



Reavaliação de evidências

Esta seção permite que a organização apresente comentários, esclarecimentos, retificações ou evidência suplementar para reavaliação de questões que tiveram pelo menos um item ou subitem classificado como não conforme na etapa de avaliação das evidências.

Consulte no Relatório Individual Preliminar e nos anexos correspondentes os itens específicos avaliados como não conformes. A apresentação de nova evidência é opcional e deve se limitar a arquivo em formato PDF ou ZIP.



Questão 0103. A organização definiu formalmente as atribuições e competências da área de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q0103 - b) a área de TI possui atribuições formalizadas relacionadas ao desenvolvimento, manutenção ou integração de sistemas
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada, composta pelo Decreto nº 7.584/2020, demonstra apenas a reorganização administrativa e o remanejamento de cargos em comissão no âmbito municipal. Não consta no referido documento a descrição das competências, atribuições ou responsabilidades formais da unidade administrativa responsável pela área de tecnologia da informação. A ausência de um regimento interno ou ato normativo equivalente que defina o escopo de atuação técnica impede a verificação dos requisitos estabelecidos para a gestão de sistemas. Faz-se necessária a apresentação de documento oficial que especifique as competências da referida unidade no que tange ao desenvolvimento, manutenção e integração de sistemas.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2101. A organização executa processo de planejamento de tecnologia da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado Q2101 - b) a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados

Resposta
informada pelo Sim
auditado
Avaliação

O documento apresentado contém apenas objetivos estratégicos e um inventário de infraestrutura, sem indicar critérios ou metodologia para a seleção e priorização de iniciativas. A evidência é insuficiente por não conter normas, matrizes ou instrumentos que definam como as ações de TI são priorizadas pela organização. Faltam registros documentais que comprovem critérios de seleção e sua manutenção atualizada.

Item avaliado Q2101 - d) o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

Resposta
informada pelo Sim
auditado
Avaliação

Embora exista o PDTIC, o material não constitui uma norma ou guia que formalize o fluxo do processo de planejamento de TI, omitindo diretrizes sobre execução e papéis institucionais. A evidência é insuficiente, pois descreve o conteúdo do plano, mas não a estrutura normativa e de governança necessária. Faltam instrumentos internos que definam responsabilidades e procedimentos para a execução do planejamento.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2102. A organização possui plano de tecnologia da informação vigente.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2102 - A organização possui plano de tecnologia da informação vigente.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A organização apresentou um documento intitulado PDTIC que, embora trate de objetivos gerais e infraestrutura, carece de elementos essenciais como data de vigência e ato formal de aprovação. O documento é insuficiente por não conter planejamento estratégico, metas ou cronogramas que caracterizem um plano de TI completo. Falta comprovação da vigência documental e elementos constitutivos mínimos de um plano de tecnologia.
Item avaliado	Q2102 - b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências que comprovem a disponibilização do plano em meio eletrônico de acesso público. A evidência enviada limita-se ao conteúdo do documento, sem qualquer link, referência ou captura de tela que demonstre sua publicação na internet. Persiste a lacuna quanto à comprovação da transparência ativa do documento.
Item avaliado	Q2102 - c) o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações
Resposta informada pelo auditado	Sim
Avaliação	O documento fornecido não apresenta vinculação com o planejamento orçamentário ou com o plano de contratações de TI. Não há menção a valores, estimativas de custos ou correlação com peças de planejamento anual. É necessária a apresentação de elementos que demonstrem como o plano orienta as decisões de investimento e contratações.
Item avaliado	Q2102 - e) é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentados registros de acompanhamento da execução do plano, tais como atas de reunião, relatórios de monitoramento ou indicadores de desempenho. O documento submetido representa apenas uma estruturação inicial, sem evidências de um processo contínuo de gestão, monitoramento ou revisão de metas. Faltam elementos comprobatórios da governança sobre a execução das atividades.



Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2202. A organização executa processo de gestão de mudanças.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2202 - A organização executa processo de gestão de mudanças.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada é um 'Termo de Compromisso de Acesso ao Sistema e Recursos', que trata exclusivamente de controle de acesso e responsabilidades de usuário. Não foram encontrados documentos ou registros que comprovem a existência ou a execução de um processo de gestão de mudanças de TI. A documentação enviada é insuficiente para sustentar a implementação do controle.
Item avaliado	Q2202 - b) mudanças são previamente comunicadas a todas as partes que possam ser afetadas
Resposta informada pelo auditado	Sim
Avaliação	Não há evidências de um processo ou registro de comunicação de mudanças de TI. O documento fornecido limita-se a disciplinar o acesso de usuários a recursos da rede, não tratando de procedimentos de comunicação prévia a partes interessadas.
Item avaliado	Q2202 - c) identificam-se os serviços e ativos de TI que possam ser afetados pela mudança, de modo a avaliar impactos em níveis de serviços acordados
Resposta informada pelo auditado	Sim
Avaliação	A evidência não demonstra a identificação de serviços ou ativos de TI afetados por mudanças, tampouco a avaliação de impactos em níveis de serviço acordados. O documento apresentado não contém elementos técnicos que comprovem a análise de impacto em mudanças de TI.
Item avaliado	Q2202 - d) a realização de cada mudança é precedida de planejamento e testes
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentados registros, planos ou evidências de testes realizados para mudanças de TI. A documentação é restrita a termos de compromisso de acesso, não contendo elementos de planejamento ou homologação técnica prévia.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

--



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2203. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2203 - A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A evidência apresentada consiste apenas em um formulário em branco de revogação de acesso, sendo insuficiente para demonstrar a existência de um processo de gestão de configuração e ativos. O documento não comprova a execução de controle sobre o ciclo de vida de ativos de TI ou a manutenção de registros operacionais. A ausência de quaisquer evidências funcionais de gestão de ativos torna o processo não verificado.
Item avaliado	Q2203 - a) a organização mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles
Resposta informada pelo auditado	Sim
Avaliação	Não há comprovação da existência de uma base de dados de configuração (CMDB) ou registro consolidado de ativos. O documento apresentado é um formulário de controle de acesso de usuários e não contém dados de configuração ou relacionamentos entre itens de serviço.
Item avaliado	Q2203 - b) a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças
Resposta informada pelo auditado	Sim
Avaliação	A evidência não demonstra a utilização de uma base de dados no planejamento ou controle de mudanças de TI. O formulário de revogação de acesso não possui qualquer vínculo com o processo de gestão de mudanças.
Item avaliado	Q2203 - c) o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
Resposta informada pelo auditado	Sim
Avaliação	Não foi apresentada norma interna, política ou guia que formalize o processo de gestão de configuração e ativos. O documento fornecido é um formulário operacional, desprovido de orientações normativas ou definição de papéis e responsabilidades para a gestão da configuração.



Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2204. A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2204 - A organização executa processo(s) de gestão de incidentes de serviços de tecnologia da informação e de incidentes de segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização não demonstra a execução efetiva do processo de gestão de incidentes. A evidência documental restringe-se a diretrizes genéricas de comunicação de incidentes à equipe de TI (páginas 2 e 4), sem apresentar registros de chamados, fluxos operacionais, níveis de serviço ou ferramentas de suporte que comprovem a operação do processo. A evidência é insuficiente por ausência de registros que demonstrem a prática da gestão de incidentes.
Item avaliado	Q2204 - a) a organização definiu regras para a priorização e o escalamento de incidentes
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas regras para priorização ou fluxo de escalonamento de incidentes. Embora a documentação apresente uma tabela de riscos com classificações, esta não se aplica à priorização operacional ou ao escalonamento hierárquico de incidentes de TI. A evidência é insuficiente por não conter os critérios necessários para o atendimento a este item.
Item avaliado	Q2204 - b) a resolução de incidentes considera os níveis de serviços especificados em acordos com as áreas clientes
Resposta informada pelo auditado	Sim
Avaliação	Não há evidência da existência de Acordos de Nível de Serviço (ANS) ou instrumentos similares pactuados com áreas clientes. A documentação enviada é omissa quanto a prazos de atendimento ou níveis de serviço esperados. Falta a comprovação documental de que os níveis de serviço são considerados na resolução de incidentes.
Item avaliado	Q2204 - e) a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa
Resposta informada pelo auditado	Sim



Avaliação	A documentação limita-se a atribuir responsabilidades genéricas e a exigir a comunicação à TI, sem detalhar procedimentos técnicos para tratamento, ações emergenciais ou fluxos de comunicação e escalonamento. A evidência é insuficiente por omitir a descrição operacional de como as notificações de incidentes de segurança são tratadas e escalonadas.
Item avaliado	Q2204 - f) a organização definiu procedimentos e responsabilidades quanto à análise dos incidentes, identificação de causas raízes e planejamento e implementação de ações corretivas
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas metodologias ou procedimentos para análise de causa raiz (RCA) ou planejamento de ações corretivas após incidentes. A documentação foca estritamente em diretrizes de gestão de risco e mitigação, sem abordar o fluxo de tratamento pós-incidente. A ausência desses procedimentos impede o cumprimento do item.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2302. A organização executa processo de gestão de riscos de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2302 - A organização executa processo de gestão de riscos de segurança da informação.
Resposta informada pelo auditado	Adota em maior parte ou totalmente.
Avaliação	A organização formalizou a governança de segurança e a política de proteção de dados, conforme Decreto nº 8.820/2024, Decreto nº 8.835/2024 e Lei nº 3.385/2024. Contudo, a evidência apresentada não comprova a execução efetiva do processo de gestão de riscos, como matrizes de risco, registros de análise de impacto e probabilidade, ou relatórios de monitoramento de risco. A documentação fornecida refere-se apenas ao estabelecimento de normas e monitoramento operacional técnico, sendo ausentes as evidências da prática de gestão de riscos propriamente dita.
Item avaliado	Q2302 - a) a organização identifica e avalia riscos de segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	Embora a legislação municipal estabeleça a necessidade de análise e gestão de riscos, não foram apresentados registros, matrizes de riscos ou relatórios metodológicos que evidenciem a realização da identificação e avaliação de riscos de segurança da informação. O monitoramento técnico de acessos apresentado não supre a necessidade de um processo formal de análise de ameaças e vulnerabilidades.
Item avaliado	Q2302 - b) a organização trata riscos de segurança da informação com base em um plano de tratamento de riscos
Resposta informada pelo auditado	Sim
Avaliação	Não há evidências documentais da existência de um plano de tratamento de riscos formalizado com ações, cronogramas e definição de responsáveis. A legislação citada prevê a governança, porém não apresenta os artefatos de controle necessários para demonstrar a execução do tratamento dos riscos identificados.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

--

Questão 2401. A organização dispõe de uma política de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2401 - c) a política abrange diretrizes para conscientização, treinamento e educação em segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	O documento apresentado não contempla diretrizes ou menções sobre ações de conscientização, treinamento ou educação em segurança da informação. A ausência de qualquer previsão programática ou educativa no texto inviabiliza a conformidade com este item.
Item avaliado	Q2401 - d) a política é amplamente comunicada a empregados, servidores, colaboradores e partes externas relevantes
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências de comunicação, divulgação ou registros de ciência da política pelos públicos abrangidos. É necessário a apresentação de elementos que comprovem a efetiva disseminação da norma entre os colaboradores e partes externas.
Item avaliado	Q2401 - e) a política é mantida atualizada, por meio de revisões periódicas
Resposta informada pelo auditado	Sim
Avaliação	O documento não apresenta histórico de revisões, data de aprovação, vigência ou diretriz que estabeleça um cronograma de revisões periódicas. A ausência de elementos de controle de versão ou previsão de manutenção torna a evidência insuficiente.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2403. A organização possui um gestor institucional de segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2403 - b) o gestor institucional de segurança da informação reporta-se diretamente à alta administração
Resposta informada pelo auditado	Sim
Avaliação	Embora o cargo de Subsecretário detenha responsabilidades estratégicas, a evidência apresentada não demonstra explicitamente a subordinação ou o reporte direto do gestor à alta administração do Executivo Municipal. Identifica-se uma lacuna documental relativa à linha de reporte hierárquico.
Item avaliado	Q2403 - f) o gestor institucional de segurança da informação detém as prerrogativas e os recursos necessários para o desempenho de todas as suas competências
Resposta informada pelo auditado	Sim
Avaliação	A documentação descreve as atribuições e o plano de ação, porém é insuficiente para comprovar a disponibilidade efetiva de recursos humanos, financeiros ou materiais dedicados ao desempenho dessas competências. Falta evidência documental que assegure a autonomia e os meios necessários para a execução integral das atividades de segurança.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2501. A organização executa processo de gestão de ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2501 - A organização executa processo de gestão de ativos associados à informação.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada consiste apenas na Política de Segurança da Informação (PSI), um documento normativo de alto nível que não comprova a efetiva execução do processo de gestão de ativos. A avaliação realizada indica a inexistência de registros operacionais, relatórios ou inventários que demonstrem a prática da gestão de ativos. A ausência de documentos comprobatórios das atividades cotidianas de inventário e monitoramento de ativos constitui a principal lacuna identificada.
Item avaliado	Q2501 - a) a organização mantém um inventário dos ativos associados à informação
Resposta informada pelo auditado	Sim
Avaliação	A organização apresentou apenas a Política de Segurança da Informação (PSI), documento que não contém ou referencia qualquer listagem, inventário ou relação detalhada dos ativos associados à informação. A evidência é insuficiente para comprovar a existência e a manutenção do inventário exigido. A principal lacuna é a ausência de um documento ou sistema que liste os ativos da organização.
Item avaliado	Q2501 - d) o processo de gestão de ativos associados à informação subsidia a implantação de controles e ações com vistas a assegurar a adequada proteção dos ativos e das informações que armazenam, processam ou transmitem
Resposta informada pelo auditado	Sim
Avaliação	Embora a PSI estabeleça diretrizes de segurança, não há evidências que demonstrem que tais controles foram definidos a partir de um processo de gestão de ativos estruturado. A documentação apresentada configura diretrizes gerais e não comprova a vinculação causal entre o inventário de ativos, a análise de suas vulnerabilidades e a implantação de controles específicos. A ausência de um processo formalizado de gestão de ativos impede o atendimento a este item.
Item avaliado	Q2501 - e) o processo de gestão de ativos associados à informação subsidia a implantação de ações mitigatórias aplicáveis no caso de ocorrência de evento catastrófico que inviabilize a utilização de ativos
Resposta informada pelo auditado	Sim
Avaliação	A PSI menciona a existência de planos de contingência, contudo, não há evidências documentais ou operacionais que comprovem a vinculação entre a gestão de ativos e as



ações mitigatórias para eventos catastróficos. A avaliação realizada indica que a evidência é meramente normativa e não comprova a execução de planos de mitigação subsidiados pela gestão de ativos. A lacuna principal é a falta de documentos que evidenciem o planejamento da continuidade baseado na criticidade dos ativos.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2502. A organização executa processo de controle de acesso à informação e aos ativos associados à informação.

Itens avaliados como não conformes nesta questão:

Item avaliado Q2502 - c) há controles de acesso lógicos na organização que utilizam autenticação com certificado digital ICP-Brasil, a fim de prover identificação inequívoca de pessoas físicas e jurídicas e comprovação de autoria em transações digitais

Resposta informada pelo auditado Sim

Avaliação Os documentos fornecidos descrevem unicamente mecanismos de autenticação baseados em login e senha, sem mencionar o uso de certificados digitais ICP-Brasil. A evidência é insuficiente para atestar a conformidade com o requisito, carecendo de qualquer registro ou norma técnica que comprove a adoção de infraestrutura de chaves públicas.

Item avaliado Q2502 - d) a organização analisa criticamente, a intervalos regulares, os direitos de acesso lógicos e físicos existentes, com vistas à remoção de direitos que deixaram de ser necessários e para assegurar que privilégios indevidos não foram obtidos

Resposta informada pelo auditado Sim

Avaliação Embora a organização possua mecanismos reativos como o Termo de Revogação, não há evidência da execução de análises críticas periódicas e estruturadas dos direitos de acesso. A evidência é insuficiente, pois faltam registros, relatórios ou atas que comprovem a revisão sistemática de privilégios de acesso concedidos aos usuários.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2503. A organização executa processo para classificação e tratamento de informações.

Itens avaliados como não conformes nesta questão:

Item avaliado Q2503 - b) a organização informa em seu sítio eletrônico as hipóteses em que, no exercício de suas competências, realiza o tratamento de dados pessoais, bem como fornece informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas de tratamento que utiliza

Resposta informada pelo auditado Sim

Avaliação Embora a legislação municipal exija a publicidade de tais informações no Portal da Transparência, a evidência apresentada consiste apenas nos diplomas normativos. Não foi fornecida prova documental, como captura de tela ou indicação de URL, que demonstre a efetiva publicação dessas informações no sítio eletrônico institucional.

Item avaliado Q2503 - e) informações críticas para a organização em razão de necessidades do negócio (p. ex. requisitos associados à integridade, disponibilidade, autenticidade ou a outros atributos da informação) são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção

Resposta informada pelo auditado Sim

Avaliação Embora o Decreto nº 8.835/2024 aborde princípios de segurança da informação (integridade, disponibilidade, confidencialidade e autenticidade), não foram apresentados critérios ou matrizes formais que estabeleçam a identificação e rotulagem das informações específicas críticas para o negócio da organização.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2504. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2504 - a) a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede
Resposta informada pelo auditado	Sim
Avaliação	Apesar da previsão normativa no Decreto nº 8.835/2024 de que apenas dispositivos autorizados podem ser conectados à rede, a organização não apresentou inventário consolidado ou registro que demonstre o controle atual dos ativos conectados. O plano de ação confirma que a manutenção de inventários é uma tarefa a ser implementada, carecendo a auditoria de prova material de que o inventário esteja em operação.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2505. A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2505 - A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada é insuficiente para demonstrar a realização periódica de ações de capacitação em segurança da informação. Embora a organização possua respaldo normativo (Decreto nº 8.835/2024 e Lei nº 3.385/2024), não foram fornecidos documentos como cronogramas, listas de presença, relatórios de turmas ou evidências de abrangência das ações. O certificado individual apresentado não comprova a continuidade ou a periodicidade das capacitações em nível organizacional.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2601. A organização executa um processo de software.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2601 - A organização executa um processo de software.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada, composta por uma listagem de repositórios em plataforma de código aberto e um Decreto de Segurança da Informação, é insuficiente para comprovar a existência de um processo de software estruturado. A captura de tela demonstra apenas a atividade de desenvolvimento, enquanto o documento normativo foca exclusivamente em diretrizes de segurança da informação institucional, sem contemplar metodologias, ritos ou formalização do ciclo de vida de desenvolvimento de software. A ausência de uma norma, guia ou evidência que detalhe o fluxo de trabalho de software impede a verificação do critério.
Item avaliado	Q2601 - a) o processo de software utilizado pela organização promove a participação de representante da área de negócio como integrante da equipe de desenvolvimento ou aquisição de software, desde sua concepção até a aceitação final
Resposta informada pelo auditado	Sim
Avaliação	Não foram apresentadas evidências documentais ou registros que demonstrem a composição de equipes multidisciplinares com a participação de representantes da área de negócio no ciclo de desenvolvimento. O material enviado não detalha o fluxo de governança de projetos, tampouco identifica ritos de interação entre a área de negócio e a equipe técnica, tornando o requisito não verificado.
Item avaliado	Q2601 - b) o processo de software da organização promove a identificação precoce de requisitos de segurança da informação e a gestão permanente desses requisitos durante todo o ciclo de vida do software
Resposta informada pelo auditado	Sim
Avaliação	A política de segurança da informação fornecida trata de diretrizes gerais para o uso de recursos tecnológicos e monitoramento de redes, não abrangendo requisitos específicos de segurança para o desenvolvimento ou aquisição de software. Não há evidência da integração de critérios de segurança no ciclo de vida de desenvolvimento, como modelagem de ameaças ou testes de segurança.
Item avaliado	Q2601 - d) a organização assegura os seus direitos autorais, de propriedade e de uso relativamente ao software que desenvolve por meio de contratação
Resposta informada pelo auditado	Sim



Avaliação

Não foram apresentados contratos, termos de referência ou documentos jurídicos que assegurem os direitos de propriedade intelectual ou de uso sobre os softwares desenvolvidos ou contratados pela organização. A evidência enviada limita-se a um decreto normativo geral e a uma página de repositórios públicos, sendo insuficiente para demonstrar a proteção patrimonial dos ativos de software.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão 2706. As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2706 - As lacunas de competências dos colaboradores e gestores da área de tecnologia da informação e de segurança da informação da organização são tratadas.
Resposta informada pelo auditado	Adota parcialmente.
Avaliação	A evidência apresentada é insuficiente para sustentar a afirmação. Os documentos referem-se a certificados de um curso sobre ferramenta administrativa (SEI), sem comprovar o tratamento de lacunas de competências específicas para colaboradores e gestores de TI ou Segurança da Informação. Há ausência de plano de capacitação, diagnóstico de lacunas e evidências de revisão ou avaliação de eficácia das ações para este público-alvo.
Item avaliado	Q2706 - b) a organização incentiva seus colaboradores e gestores a participar das ações de capacitação existentes
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada não demonstra a existência de mecanismos organizacionais de incentivo. Os certificados comprovam apenas a participação em um curso externo de uso de sistema administrativo, sem evidenciar atos, comunicações internas ou políticas da organização que incentivem a capacitação dos colaboradores e gestores.
Item avaliado	Q2706 - c) a organização monitora a participação dos colaboradores e gestores nas ações de capacitação existentes
Resposta informada pelo auditado	Sim
Avaliação	Não há evidência de monitoramento sistemático pela organização. Os documentos apresentados são certificados emitidos por terceiros, não constituindo relatórios, indicadores ou registros internos que comprovem a atividade de monitoramento da participação nas ações de capacitação.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO
SECRETARIA-GERAL DE CONTROLE EXTERNO – SGE
SUBSECRETARIA DE CONTROLE DE POLÍTICAS DE CIDADANIA
COORDENADORIA DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

Apenas um arquivo PDF ou ZIP



Questão 2708. A organização possui em sua estrutura cargos específicos em tecnologia da informação e segurança da informação.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2708 - d) a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação
Resposta informada pelo auditado	Sim
Avaliação	A avaliação realizada indica que o item está não conforme. A análise da documentação apresentada não identificou cargo, função, norma ou ato de designação que mencione explicitamente atribuições relativas à segurança da informação. A evidência é insuficiente para comprovar a existência da estrutura requisitada. Torna-se necessária a apresentação de documento oficial que atribua formalmente tal responsabilidade.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP



Questão 2802. A organização executa processo de planejamento anual das contratações.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2802 - a) a alta administração (ou conselho ou colegiado superior) aprova formalmente o Plano de Contratações Anual (PCA)
Resposta informada pelo auditado	Sim
Avaliação	Embora o PCA tenha sido apresentado, não há evidência da sua aprovação formal pela autoridade superior competente. O documento carece de ato administrativo, assinatura, decreto, resolução ou despacho que formalize a deliberação da alta administração sobre o plano. É necessário a apresentação do respectivo ato de aprovação.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP

Questão Caso tenha assinalado que as contratações de soluções de TI são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI, forneça evidência de norma regulamentando esse processo e de um caso concreto.

Itens avaliados como não conformes nesta questão:

Item avaliado	Q2804 - a) as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI
Resposta informada pelo auditado	Sim
Avaliação	A evidência apresentada consiste unicamente no Plano de Contratações Anual (PCA) do exercício de 2026, o qual apenas relaciona objetos e estimativas de despesas. O documento é insuficiente para demonstrar o controle de governança afirmado, pois não apresenta normas, portarias, fluxogramas ou regimentos que estabeleçam a obrigatoriedade da análise técnica prévia pela gestão de tecnologia da informação. Adicionalmente, não foram fornecidos registros de casos concretos que comprovem a efetiva submissão de contratações dessa natureza à chancela técnica da área de TI.

Caso deseje, apresente comentários, esclarecimentos ou retificações sobre a avaliação de evidências desta questão.

Caso deseje, envie uma evidência suplementar para reavaliação.

Apenas um arquivo PDF ou ZIP